CS205 MIDTERM CURRENT PAPER 2023 SOLVED BY PRINCE ALVI

MCQS

1) EAP-TLS support ____on WLAN client to provide more significant protection
Two-factor user authentication

2) DISA is a standard of_____
Defense Information Systems Agency

3) MS exchange server falls under category of Which CIS benchmark.
DESKTOP SOFTWARE

4) _____category has maximum number of CIS benchmark.
OPERATING SYSTEMS 36

5) _____is the most important activity to be followed before implementing controls in production.
Assessing security risks and gaps Or Pilot (test) Or Develop SOPs and checklists

6) _____enterprises have their own vulnerability scanner.
5%

7) Information security is a combination of_____.
People, process, and technology

8) What is the function of active directory in an enterprise network?
Active Directory stores information about objects on the network and makes this information easy for administrators and users to find and use. Active Directory uses a structured data store as the basis for a logical, hierarchical organization of directory information

9) What are the most basic security tools an enterprise must have?
Firewall, Antivirus/anti-malware software, Spam filter, Web filter, Intrusion detection and prevention system (IDPS), Virtual private network (VPN) & Password manager

10) How web and email can be secured against malware and attacks in enterprises.
By blocking unauthorized traffic at edge

11) One of the main challenge in small size organizations related to security is_____.
Lack of budget and resources allocated for security

12) The key challenge with Mobile technology is_____.
Traditional enterprise security perimeter and boundary has disappeared

13) Purpose of SIEM solution is_____.

SOLVED BY PRINCE ALVI 9222@GMAIL.COM

For any query feel free to ask princealvi9222@gmail.com

CS205 MIDTERM CURRENT PAPER 2023 SOLVED BY PRINCE ALVI

The main purpose of a SIEM solution is to provide a centralized platform for collecting, analyzing, and reporting on security-related data from a variety of sources, such as network devices, servers, applications, and security systems.

14) Major security functions performed by NGN firewall_____.
Apt attack prevention

15) Next generation firewall should be placed at_____.
At the network perimeter and at the entrance to the data center

16) PECA enacted as late as_____.
2016

17) Challenges of information security_____.
Cloud and Iot

18) What is vulnerability management _____?
Vulnerability is a cyber-security term that refers to a flaw in a system that can leave it open to attack. A vulnerability may also refer to any type of weakness in a computer system itself, in a set of procedures

19) Ransomware is_____.
A type of attack that encrypts data on computers and servers

20) Pillars of information security _____.
Confidentiality, integrity, accessibility

Subjective:

1) Transformation frameworks layers name only
1. Security hardening
2. Vulnerability management
3. Security engineering
4. Security governance

2) SSH protocols version names
There are mainly two versions of SSH protocol. The initial version was SSH-1, which was released in July 1995. In 2006, IETF (Internet Engineering Task Force) published RFCs for a revised version of the SSH protocol SSH-2 as the standard. The two versions of SSH, SSH-1 and SSH-2 are not compatible.

3) CIS benchmarks layers name and which category has minimum
OVERALL CIS BENCHMARK CATEGORIES

SOLVED BY PRINCEALVI9222@GMAIL.COM

For any query feel free to ask princealvi9222@gmail.com

CS205 MIDTERM CURRENT PAPER 2023 SOLVED BY PRINCE ALVI

1 OPERATING SYSTEMS 36
2 SERVER SOFTWARE 33
3 CLOUD PROVIDERS 2
4 MOBILE DEVICES 8
5 NETWORK DEVICES 6
6 DESKTOP SOFTWARE 21
7 MULTIFUNCTION PRINT DEVICES 1
GRAND TOTAL CIS BENCHMARKS 107

4) What is security awareness?
Security awareness is the knowledge and attitude members of an organization possess regarding the protection of the physical, and especially informational, assets of that organization.

5) Difference between cis & disa
CIS has defined benchmarks for each of those platforms, but DISA has the more generic Cloud Computing SRG. There are also many notable examples beyond these where DISA has a STIG, and CIS does not. For instance, IBM WebSphere (zip), Red Hat JBOSS, and F5 BigIP all have STIG content, but no corresponding CIS baseline.

6) Security box explain
"Box Security" refers to a prevalent approach in the industry, especially in larger organizations in which the solution for every security challenge is in the form of a "box" or device
Box for:
– Email security – Web security – FW – IPS – APT attack
prevention
– DDOS prevention – Network DLP – Network Forensics – Others

7) Main security models
1. Security Hardening
2. Vulnerability Management
3. Security Engineering
4. Security Governance

8) Configuration level of CIS benchmarks (5)
CIS benchmarks are configuration baselines and best practices for securely configuring a system. Each of the guidance recommendations references one or more CIS controls that were developed to help organizations improve their cyber defense capabilities.

9) Write any five steps of information security program (5)
• **Information security program**
– Assessing security risks and gaps
– Implementing security controls
– Monitoring, measurement, & analysis

SOLVED BY PRINCEALVI9222@GMAIL.COM

For any query feel free to ask princealvi9222@gmail.com

– Management reviews and internal audit
– Accreditation/testing

10) Information security defined by SANS (3)
• Protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction. **(SANS)**

11) Prerequisites of security hardening
1. Security program approved
2. Consultant on board
3. Project kick-off meeting held
4. ISMC team identified and their loading for this project communicated
5. Appraisal linkage of core resources announced by CIO

12) What is cyber security?
– Precautions taken to guard against unauthorized access to data (in electronic form) or information systems connected to the internet
– Prevention of crime related to the internet

13) What are the layers of IS?
1. Security hardening
2. Vulnerability management
3. Security engineering
4. Security governance

14) Steps of information flow process?
The steps of the information flow process may include additional steps or considerations to ensure the confidentiality, integrity, and availability of the information.

15) Security hardening k steps aye thy
Security Hardening
1. Identify critical assets (& asset owner)
2. Research on applicable security controls
3. Checklist of applicable controls
4. Document controls into SOP
5. Implement controls on test setup
6. Validation of control implementation
7. Change management process for PROD
8. Implement on PROD & monitor

16) Enterprise k lye main components aye thy
• Edge router
• NGN FW

SOLVED BY PRINCEALVI9222@GMAIL.COM

• DMZ:
• IPS:
• Distribution switch
• Data center switch & FW
• Access switch
• NAC
• SIEM
• Vulnerability Manager
• System AV
• Server HIPS
• UTM
• Mobile device

17) DISA stig contents names
– General information (title)
– Discussion
– Check content
– Fix text
– CCI (References)

18) Backup Strategies consideration
• Backup considerations:
– What to back up?
– Backup location?
– Free of backup?
– Backup operator?
– Backup checker (verification)?
– Backup test & security methods?
– Technology & tools used for backup?

19) Security tools in an Enterprise
Typical security tools used in an enterprise:
– Enterprise antivirus
– MS Active Directory (AD)
– Vulnerability manager
– Logs management
– Network & performance monitoring
– Automated backups

20) Three InfoSec functions
InfoSec functions:
– Governance
– Policies & procedures

SOLVED BY PRINCEALVI9222@GMAIL.COM

– Risk management
– Performance reviews

21) Software security workflow

1. Research Security Controls
2. Apply Security Controls (Hardening)
3. Code Review & Automated Testing (Validation)
4. Harden Server Environment
5. Pen Test & Accreditation (Move to PROD)

22) Challenges of box security

"Box Security" refers to a prevalent approach in the industry, especially in larger organizations in which the solution for every security challenge is in the form of a "box" or device
There are several challenges that can arise when implementing security for a "box" or physical device, such as a server, desktop computer, or IoT device.

23) Information security program

– Assessing security risks and gaps
– Implementing security controls
– Monitoring, measurement, & analysis
– Management reviews and internal audit
– Accreditation/testing

SOLVED BY PRINCEALVI9222@GMAIL.COM